

Paper Code



Coláiste na Tríonóide, Baile Átha Cliath
Trinity College Dublin

Ollscoil Átha Cliath | The University of Dublin

Faculty of Engineering, Mathematics and Science

School of Computer Science & Statistics

MSc in Computer Science Hilary Term 2025 Year 1

Security of Networks and Distributed Systems

CS7NS5/CSU44032

dd MMM 2025

Location

Time (2 hours)

Dr. Stephen Farrell

Instructions to Candidates:

Attempt **three** questions. All questions carry equal marks (40 each).

You may not start this examination until you are instructed to do so by the invigilator.

Materials Permitted for this examination:

N/A

Question 1

An Irish ISP is planning to deploy an upgraded customer support chatbot for their web site using a new Large Language Model (LLM) with additional training using general company data. The chatbot will also have access to live customer data. Chatbot training and testing is to be carried out using a mixture of ISP staff and contractors. The underlying LLM requires use of the LLM provider's online service via the APIs defined for that service, but company-specific and customer data are stored in databases that are operated by the ISP. You are tasked to carry out a risk analysis to help inform the ISP of the risks they may face during training, deployment and use of the new chatbot.

You may assume any realistic setup for LLM training and runtime access. Bear in mind that your answer should be about risk analysis, risks and mitigations, and not (so much) about LLMs, so you do not need to be highly specific or accurate as to LLM details. You can also assume that the chatbot is only offered via the ISP's web site and don't need to consider other channels such as instant messaging platforms etc.

(a) Describe the process you would use to carry out this task (note: this part of the question asks about process, not the specific risks associated with the new system).

[15 marks]

(b) Describe three significant risks affecting the planned system, including their potential impact and likelihood of occurrence, and outline countermeasures you would recommend that the ISP ought apply.

[15 marks]

(c) What risks that potentially affect end users should be considered, and what actions would you recommend be taken to mitigate those risks?

[10 marks]

Question 2

(a) For any real Internet key exchange protocol (e.g. TLS, IPsec, or Kerberos) describe the key management and application data protection aspects of the protocol in detail. Describe how a library developer, for example the OpenSSL project for the TLS protocol, might test their implementation.

Your answer may describe any widely used version of your chosen protocol, but for TLS, you must explicitly state which version you are describing.

[25 marks]

(b) Outline the ways in which the security of your chosen protocol depends on other infrastructure such as the Internet routing system, the domain name system or a key management infrastructure, such as the Web-PKI for TLS as used in the web.

[10 marks]

(c) What security-relevant differences might arise for enterprises when comparing self-hosted versus cloud-hosted deployments of your chosen protocol?

[5 marks]

Question 3

The Irish national health authority (the Health Services Executive, HSE) have recently (February 2025) introduced the “HSE Health App,” a mobile app for the IOS and Android platforms that allows users to access public healthcare information, but to also (for authenticated users) manage appointments with healthcare providers, store vaccination and medicine/prescription information, and with additional functions to be added over time. The app interacts with various back-end services operated by (or for) the HSE as well as with services operated by other healthcare providers (e.g. hospital groups, general practitioners). Generally, the system is a fairly typical mobile web application using APIs provided by services, with some server-server interactions in the background, but this system is dealing with highly sensitive healthcare information and is intended to eventually be used at the scale of the entire population, so security and privacy has to be a primary consideration and we can be sure the system will be attacked by various bad actors.

For the purposes of this question, assume we are back at the start of the design process and you are tasked with producing a security and privacy design for the overall system. In answering, pay attention to the marks allocated for each of parts (a)-(c) below.

(a) Outline a design for the overall system (include diagrams as appropriate), and state the security and privacy requirements the overall system should meet. Note that this part of your answer should only discuss security and privacy requirements and not describe specific mechanisms to meet those requirements.

[20 marks]

(b) Describe, in detail, the security and privacy mechanisms you would propose for the system to meet requirements related to handling appointments from part (a).

[15 marks]

(c) If you were a motivated and well-resourced bad actor, outline how would you go about planning an attack on this system with the goal of exfiltrating user data if possible, or at least denying service to users?

[5 marks]

Question 4

(a) Describe in detail how DNS query resolution for typical address records works, including, at each stage, potential attacks and mitigations. How do DNSSEC related resource records affect resolver performance if/when DNSSEC is used?

[15 marks]

(b) Describe ways in which the Web-PKI and the DNS are intertwined, and three attacks on the DNS that affect the Web-PKI.

[15 marks]

(c) How do privacy issues arise in connection with the use of the DNS? How are those affected by the use of DNS-over-TLS (DoT) or DNS-over-HTTPS (DoH)? What default DNS privacy setup would you recommend for a current mobile operating system? Say why you consider that a reasonable default, and how it would affect those privacy issues.

[10 marks]